SIMATS ENGINEERING

Saveetha Institute of Medical and Technical Sciences

CSA6303 - Threat Intelligence and Network Security

A2 - Vulnerability Assessment Report

Assessment Questions - Answers

Subject	Threat Intelligence
Total Marks	50
Questions	10 (all compulsory)
CO2	Identify common network attacks and analyze threat intelligence sources and data collection techniques
Reg. No	192465038
Name of the Student	T. Raju

Code of Conduct

I T. Raju / 192465038 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student: _____

Q1. Common Network Attacks: Malware, Phishing, DoS and DDoS [10 Marks]

1. Malware

Malware is malicious software designed to damage, disrupt or gain unauthorised access to a system. Main types:

Type	Description	Example
Virus	Attaches to a host file or program and spreads when the infected file is run	CIH (Chernobyl) virus
Worm	Self-replicates across networks without user action by exploiting vulnerabilities	WannaCry (SMB flaw), Morris worm
Trojan	Disguised as legitimate software; opens backdoors or steals data	Zeus banking trojan
Ransomware	Encrypts files and demands payment for the decryption key	LockBit, WannaCry, Ryuk
Spyware	Secretly records keystrokes, browsing and credentials	Keyloggers, Pegasus

Preventive measures: up-to-date antivirus / EDR, timely patching, application whitelisting, email attachment filtering, regular offline backups and avoiding untrusted downloads.

2. Phishing

Phishing is a social-engineering attack in which deceptive emails, SMS messages, links or fake websites impersonate a trusted entity to trick users into revealing credentials, OTPs or financial data, or into installing malware. Variants include spear phishing (targeted), whaling (executives), smishing (SMS) and vishing (voice).

Example: a fake "bank account suspended" email linking to a look-alike login page that captures the victim's username and password. **Preventive measures:** user awareness training, spam filtering with SPF/DKIM/DMARC, multi-factor authentication, checking URLs before clicking, and a reporting process for suspicious mail.

3. DoS (Denial of Service)

A DoS attack floods a target server or network from a **single source** with excessive requests or malformed packets so that legitimate users cannot access the service. **Example:** ping flood, SYN flood or Ping of Death. **Preventive measures:** rate limiting, SYN cookies, firewall / IPS rules to block the offending source, and patching vulnerable services.

4. DDoS (Distributed Denial of Service)

A DDoS attack uses **many compromised devices (a botnet)** controlled through command-and-control servers to flood the victim simultaneously. It is far larger and harder to block because traffic comes from thousands of genuine-looking IP addresses. **Example:** the Mirai botnet attack on Dyn DNS (2016). **Preventive measures:** CDN and traffic-scrubbing services, load balancing and over-provisioned bandwidth, anycast routing, blackhole routing and DDoS protection from the ISP.

Attack	Goal	One preventive measure
Malware	Damage, theft, control	Antivirus / EDR with patching
Phishing	Steal credentials / deliver malware	User awareness training + MFA
DoS	Exhaust resources from one source	Rate limiting / firewall
DDoS	Exhaust resources from a botnet	CDN and traffic scrubbing

Q2. Man-in-the-Middle (MitM) Attack [8 Marks]

Definition: A MitM attack is one in which an attacker secretly intercepts, and possibly alters, the communication between two parties who believe they are communicating directly. It compromises **confidentiality** (eavesdropping) and **integrity** (data tampering).

How it works

- **Interception:** the attacker positions themselves in the communication path (on the LAN, a Wi-Fi network or by redirecting DNS).
- **Decryption / relay:** traffic is captured, and where encryption exists it is downgraded or terminated by the attacker.
- **Manipulation and forwarding:** data may be read, modified or injected, then forwarded so that neither side notices.

Techniques

- **ARP poisoning:** forged ARP replies map the attacker's MAC to the gateway's IP, so LAN traffic flows through the attacker.
- **Rogue Wi-Fi access point (evil twin):** a fake hotspot with a familiar SSID lures users, and all their traffic passes through the attacker.
- **DNS spoofing:** false DNS responses redirect users from a real domain to an attacker-controlled site.
- **Session hijacking:** the attacker steals a session cookie or token and takes over an authenticated session.
- **SSL stripping:** an HTTPS connection is downgraded to HTTP so data is visible in clear text.

Countermeasures

- HTTPS/TLS with strong ciphers and proper **certificate validation**; **HSTS** to prevent downgrade.
- **VPN** on untrusted networks; avoid public Wi-Fi for sensitive tasks.
- **Dynamic ARP inspection**, DHCP snooping, port security and static ARP entries for critical hosts.
- DNSSEC, multi-factor authentication, secure cookies and short session lifetimes.

Q3. Spoofing vs Sniffing [8 Marks]

Aspect	Spoofing	Sniffing
Definition	Forging identity (address, name or source) to impersonate a trusted entity	Passively capturing and inspecting packets travelling on a network
Nature	Active attack	Passive attack
Objective	Gain trust, bypass filters, redirect traffic, hide the attacker's origin	Eavesdrop on credentials and data
Effect on traffic	Packets are crafted or altered	Traffic is not modified; difficult to detect
Tools	Hping, Ettercap, arpspoof	Wireshark, tcpdump

Types of spoofing

- **IP spoofing:** forging the source IP of packets (used in DDoS reflection and trust bypass).
- **MAC spoofing:** changing the MAC address to impersonate a device or bypass MAC filtering.
- **ARP spoofing:** fake ARP replies redirect LAN traffic through the attacker.
- **Email spoofing:** forged "From" address, used in phishing and BEC fraud.
- **DNS spoofing / cache poisoning:** false DNS records send users to malicious sites.

Sniffing: detection and prevention

Sniffing mainly exposes **unencrypted** data (HTTP, FTP, Telnet, SMTP) and works best on hubs, Wi-Fi or a compromised switch port.

- **Detection:** look for NICs in promiscuous mode (e.g. with Nmap scripts or AntiSniff), unusual ARP traffic or duplicate MAC / IP pairs, and use IDS alerts such as Snort or Zeek.

- **Prevention:** encrypt traffic with HTTPS, SSH, SFTP and VPN; use switched networks instead of hubs; apply port security and dynamic ARP inspection; use WPA3 on Wi-Fi.
- **Anti-spoofing filters:** ingress/egress filtering (BCP 38), reverse-path forwarding checks and SPF/DKIM/DMARC for email.

Q4. Vulnerability Assessment and Report [8 Marks]

Definition: Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications so that they can be fixed before an attacker exploits them.

Steps

- **Asset identification:** inventory hosts, devices, applications and define scope.
- **Scanning:** run automated scanners such as **Nessus** or **OpenVAS** (also Qualys) to find missing patches and misconfigurations.
- **Analysis:** validate results, remove false positives and map findings to CVE IDs.
- **Risk rating:** score with CVSS and adjust for asset criticality and exploitability.
- **Reporting and remediation:** document findings, fix, and rescan to verify.

Contents of a good vulnerability assessment report

Section	Contents
Executive summary	Non-technical overview: overall risk, key findings and business impact
Scope and methodology	Systems and IP ranges tested, dates, tools used, approach (credentialed / non-credentialed)
Findings	Vulnerability name, affected host, **CVE ID**, **CVSS severity score** (Critical / High / Medium / Low)
Evidence	Scanner output, screenshots, proof of detection
Risk impact	Possible consequences such as data breach or downtime, and exploitability
Remediation	Prioritised recommendations: patch, configuration change, workaround, with owners and timelines
Appendix	Tool details, full scan results, references

Vulnerability assessment vs penetration testing

Aspect	Vulnerability assessment	Penetration testing
Purpose	Identify and list weaknesses	Exploit weaknesses to prove real impact
Method	Mostly automated, broad coverage	Manual, expert-driven, in-depth
Output	Prioritised list of vulnerabilities	Attack paths and proof of compromise

Q5. OSINT, Threat Data Sources and Collection Techniques [8 Marks]

OSINT (Open-Source Intelligence): intelligence produced from publicly and legally available information that is collected, analysed and used to answer a specific security question, such as identifying attacker infrastructure or an organisation's exposed assets.

Threat data sources

Category	Sources
Open-source (OSINT)	**WHOIS** (domain registration), **Shodan** (exposed devices and services), social media, news sites, forums and paste sites, code repositories (GitHub), **CVE / NVD** databases, VirusTotal

Category	Sources
Commercial	Paid intelligence from vendors such as Recorded Future, Mandiant and CrowdStrike: curated, analysed and supported
Internal	Firewall, IDS/IPS, DNS, proxy and server logs, SIEM data, endpoint telemetry, **honeypots**, past incident reports
Community / external	ISACs, CERT-In advisories, information-sharing groups, MISP communities

Collection techniques

- **Passive collection:** gathering data without touching the target (search engines, public records, certificate transparency, archived pages).
- **Web scraping and crawling:** automated extraction from websites, forums and paste sites.
- **DNS and domain lookups:** WHOIS, reverse DNS, passive DNS and subdomain enumeration to map infrastructure.
- **Honeypots and sensors:** decoy systems that record attacker behaviour and malware samples.
- **Monitoring and feeds:** social media, dark-web and leak-site monitoring; ingesting threat feeds.

Legal and ethical considerations

- Collect only publicly accessible data; do not bypass logins or hack to obtain information.
- Respect privacy laws (e.g. GDPR, India's IT Act and DPDP Act) and website terms of service.
- Avoid active probing of third-party systems without authorisation, handle personal data minimally, and verify source reliability before acting.

Q6. Indicators of Compromise (IoCs) and Threat Feeds [8 Marks]

Definition: Indicators of Compromise are forensic artefacts or pieces of evidence that show a system or network has been breached or is being attacked. They are found in files, logs, endpoints and network traffic.

Types of IoCs

Type	Examples
File-based	File hashes (MD5, SHA-256) of known malware, malicious file names and paths, YARA signatures
Network-based	Malicious IP addresses, domains and URLs, C2 communication, unusual outbound traffic or DNS beaconing, abnormal ports
Host-based	Suspicious registry keys, new unauthorised accounts, unexpected processes or services, scheduled tasks, modified system files
Behavioural	Unusual login times or locations, large data transfers, privilege escalation

How threat feeds help improve defence

A threat intelligence feed is a continuous, machine-readable stream of IoCs (malicious IPs, domains, URLs, hashes) from **open-source** providers (AlienVault OTX, abuse.ch, MISP) or **commercial** vendors. Feeds use formats and standards such as **STIX** (describes the data) and **TAXII** (transports it). They help organisations by:

- Feeding indicators automatically into **SIEM, firewalls, IPS and EDR** to block known-bad IPs, domains and files.
- Enabling **faster detection** and alert enrichment, since analysts see context for a suspicious indicator immediately.
- Supporting **proactive threat hunting** across logs and endpoints, and reducing response time.
- Providing early warning of new campaigns and sharing intelligence with peers.

Limitations

- **False positives** that create alert noise and may block legitimate services.
- **Stale data:** IPs and domains change quickly, so old indicators lose value.

- **Need for context:** raw indicators without relevance to the organisation, confidence or source reliability need analyst validation.